

Company: Hail Software LTD
Assessment type: Cybersecurity Assessment
Conducted by: Rodrigo da Silva
Date: August 2026

01 – Executive Summary

This cybersecurity risk assessment was conducted to help the client, “Hail Software LTD,” understand their current security posture and identify potential system vulnerabilities that could impact their CIA triad (confidentiality, integrity, and availability).

Hail Software LTD is a small Tech / Finance company that develops financial reconciliation software for its clients. Their employees operate through a hybrid working model, go to the office in London, and store their corporate data and infrastructure in cloud-based services.

Nine security findings were identified across the organisation’s identity and access management, data security, business continuity, security governance, vulnerability management, endpoint security, and security awareness.

Out of these 9 findings, six were categorised as High priority and three as Medium priority.

Inconsistent multi-factor authentication, lack of centralised identity management, exposure of sensitive information, absence of a documented incident response plan and security policies stood out as the most significant potential security risks.

A priority action plan to secure their environment completely needs to include strengthening authentication and access controls, establishing clear emergency procedures in case of breaches, formalising and documenting security policies and introducing routine vulnerability scanning and patching.

02 – Client Profile

Organisation: Hail Software LTD

Industry: Technology / Finance

Personnel: 45

Working model: Hybrid

Cloud Computing Platform: AWS

Database: PostgreSQL

Productivity Platform: Google Workspace

Source Code Repository: GitHub

Communication: Slack, Zoom and Teams

Endpoint Environment: Corporate and BYOD devices

As Hail Software develops financial reconciliation software for their clients, this requires strict confidentiality and compliance. Therefore, remote working, third-party SaaS applications and BYOD devices present significant security risks, making appropriate security controls indispensable.

03 - IT Infrastructure

Cloud Computing: AWS servers executing the PostgreSQL database system.

Authentication allows users to use Google Workspace for email and file sharing.

Development enables users to create source code repositories in GitHub.

04 -Vulnerabilities and Weaknesses

Access Control does not enforce MFA (multi-factor authentication) for all Slack and GitHub users.
Asset management allows employees to use non-firm-approved equipment without installing proper firm firewalls and antivirus settings.
Sensitive data can be easily tracked on Google Drive.
Processes do not include an incident response plan or a regular manual backup plan.

05- Assessment Scope

The assessment was carried out using a structured review of Hail Software LTD's hypothetical technology environment, security processes and existing controls.

The assessment focused on identifying potential gaps between the organisation's current practices and relevant information security principles aligned with ISO 27001.

06 – Assessment Methodology

The assessment considered:

- Identity and access management
- Authentication and credential management
- Cloud security
- Data protection
- Incident management
- Vulnerability management
- Endpoint security
- Security policies
- Security awareness and training

Findings were evaluated for likelihood and business impact and categorised as High or Medium priority.

Review the complete assessment details and tailored recommendations below:

ID	Finding	Likelihood	Impact	Risk	Recommendation	Priority
F-01	MFA not enforced	High	High	Critical	Enforce MFA	Immediate
F-02	SSO not enforced	Medium	High	High	Implement central IdP/SSO	High
F-03	Sensitive data exposure	High	High	Critical	Review access and data controls	Immediate
F-04	No incident response plan	Medium	High	High	Develop IR procedure	High

ID	Finding	Likelihood	Impact	Risk	Recommendation	Priority
F-05	Lack of security policies	Medium	High	High	Develop security policy framework	High
F-06	No routine vulnerability scanning	Medium	High	High	Establish vulnerability scanning	High
F-07	BYOD weaknesses	High	Medium	High	Implement BYOD/MDM/EDR controls	High
F-08	No permission audits	Medium	Medium	Medium	Quarterly access reviews	Medium
F-09	Limited security training	Medium	Medium	Medium	Mandatory security awareness training	Medium

07 – Action-oriented plan aligned with ISO 27001

07.1. Purpose

The following remediation plan aligns with the ISO 27001 information security control areas identified during the assessment, with a particular focus on authentication, access control, information protection, incident management, vulnerability management, endpoint security and security awareness. The mitigation plan is based on the High and Medium risks identified in the assessment.

07.2. High-Priority Mitigation Plan

F-01 — Multi-Factor Authentication

Finding:

MFA is not enforced for all Slack and GitHub users.

Risk:

Compromised credentials could allow unauthorised access to corporate systems and source-code repositories.

ISO 27001 alignment:

Annex A 5.8 — Secure Authentication

Mitigation

Hail Software LTD should implement MFA across all corporate accounts, beginning with Slack and GitHub and prioritising privileged and high-risk accounts.

The organisation should:

- Enable MFA for all users.
- Prioritise administrative and privileged accounts.

- Establish a process for monitoring MFA adoption.
- Review exceptions where MFA cannot be implemented.
- Periodically review authentication controls.

Responsible owner: IT/Security Lead

Deadline: 30 days

Priority: Critical

Expected outcome:

Reduced risk of account compromise resulting from stolen or compromised passwords.

F-02 — Central Identity Provider / SSO

Finding:

A central Identity Provider and SSO are not enforced consistently across platforms.

Risk:

Multiple independent authentication mechanisms can make account management and access control more difficult and increase the possibility of inconsistent security configurations.

ISO 27001 alignment:

Annex A 5.16 — Identity Management

Annex A 5.18 — Access Rights

Mitigation

Hail should evaluate and implement a centralised identity-management approach using an appropriate Identity Provider and SSO solution.

The implementation should include:

- Centralised user identity management.
- Consistent authentication requirements.
- MFA integration.
- Centralised account provisioning and deprovisioning.
- Removal of access when employees leave.
- Periodic review of user access.

Responsible owner: IT/Security Lead

Deadline: 60 days

Priority: High

Expected outcome:

Improved control over identities, authentication and user access across corporate services.

F-03 — Sensitive Data Protection

Finding:

Sensitive data is easily accessible/tracked through Google Drive.

Risk:

Inappropriate access or sharing could result in unauthorised disclosure or loss of sensitive information.

ISO 27001 alignment:

Annex A 8.11 – Data Masking

Annex A 8.12 – Data Leakage Prevention

Annex A 8.24 – Use of Cryptography

Mitigation

Hail should protect its sensitive data:

- Identify and classify sensitive information.
- Review Google Drive permissions.
- Apply least-privilege access.
- Restrict external sharing.
- Review who can access sensitive files.
- Implement appropriate monitoring and data-loss prevention controls where appropriate.
- Establish retention and secure disposal requirements.
- Review whether specific information should be stored in AWS or another approved environment based on business and security requirements.

Responsible owner: IT/Security Lead + Data/Business Owner

Deadline: 60 days

Priority: High

Expected outcome:

Reduced likelihood of unauthorised disclosure or inappropriate access to sensitive information.

F-04 — Incident Response

Finding:

Hail does not currently have a documented incident response plan.

Risk:

Employees may not know how to identify, report, contain or respond to a security incident, increasing potential operational impact.

ISO 27001 alignment:

Annex A 5.24 – Information Security

Annex A 5.28 – Incident Management

Mitigation

Develop and implement a formal Incident Response Plan covering:

Identify – Report – Contain – Investigate – Recover – Lessons Learned

The plan should define:

- What constitutes a security incident.
- How employees report incidents.
- Who is responsible for managing incidents.
- Escalation procedures.
- Communication channels.
- Evidence preservation.
- Recovery procedures.
- Post-incident review.

The procedure should subsequently be tested through a simulated incident/tabletop exercise.

Responsible owner: Security Lead

Deadline: 30 days

Priority: High

Expected outcome:

A consistent and structured response to cybersecurity incidents.

F-05 — Security Policies

Finding:

Hail lacks formal security policies covering company procedures.

Risk:

Without documented requirements, employees may apply security practices inconsistently.

ISO 27001 alignment:

Clause 5.2 – Information Security Policy

Annex A 5.1 — Policies for Information Security

Mitigation

Develop a documented information security policy framework.

Initially, Hail should create:

1. Information Security Policy
2. Access Control Policy

3. Acceptable Use Policy
4. BYOD Policy
5. Incident Response Procedure
6. Vulnerability Management Procedure

Each document should have:

- Purpose
- Scope
- Responsibilities
- Security requirements
- Exceptions
- Review frequency
- Approval authority

Responsible owner: Security Lead / Management

Deadline: 60 days

Priority: High

Expected outcome:

Clearly documented security responsibilities and consistent organisational security practices.

F-06 — Vulnerability Management

Finding:

Lack of routine vulnerability scanning process.

Risk:

Security weaknesses may remain unidentified and unremedied, increasing exposure to attacks.

ISO 27001 alignment:

Annex A 8.8 — Management of technical vulnerabilities

Mitigation

Establish a vulnerability management process that includes:

Identify – Assess – Prioritise – Remediate – Verify

The organisation should:

- Conduct routine vulnerability scans.
- Prioritise vulnerabilities based on severity and business impact.
- Assign remediation owners.
- Establish remediation deadlines.

- Track unresolved vulnerabilities.
- Perform follow-up scans to verify remediation.

Responsible owner: IT/Security Team

Deadline: 60 days

Priority: High

Expected outcome:

Improved visibility of technical weaknesses and a repeatable remediation process.

07.3. Medium Priority Mitigation Plan

F-07 — BYOD / Endpoint Security

Finding:

Employees can use personal and corporate devices that may not have appropriate firewall, antivirus or other security controls.

Risk:

Unmanaged or inadequately protected devices could provide an entry point into corporate systems.

ISO 27001 alignment:

Annex A 7.13 – Equipment Maintenance

Annex A 8.1 – Endpoint Devices

Annex A 8.20 – Network Security

Mitigation

Implement a formal BYOD security policy establishing minimum security requirements for personal devices accessing company systems.

Requirements should include:

- Supported operating systems.
- Mandatory security updates.
- Device encryption.
- Firewall enabled.
- Endpoint protection.
- Screen lock/password requirements.
- Ability to remove corporate access when necessary.
- Restrictions on accessing sensitive systems from unmanaged devices.

Where appropriate, Hail should evaluate **MDM and/or EDR** solutions.

Responsible owner: IT/Security Lead

Deadline: 90 days

Priority: Medium

F-08 — Quarterly Access Reviews

Finding:

Absence of planned audits to review user permissions.

Risk:

Users may retain unnecessary access after changing roles or leaving the organisation.

ISO 27001 alignment:

Annex A 5.16 – Identity and Access Management

Annex A 5.18 – Access Rights Control

Mitigation

Implement a quarterly user-access review.

Each review should verify:

- User identity.
- Current role.
- Applications accessed.
- Permissions granted.
- Privileged access.
- Whether access remains necessary.

Any unnecessary access should be removed promptly.

Responsible owner: IT/Security Lead + Department Managers

Deadline: Begin within 60 days, then quarterly

Priority: Medium

F-09 — Security Awareness Training

Finding:

Employees receive security training during onboarding but do not receive regular mandatory training.

Risk:

Employees may remain vulnerable to phishing, social engineering, credential theft and other common threats.

ISO 27001 alignment:

Annex A 6.3 — Information Security Awareness, Education and Training

Mitigation

Implement a recurring security awareness programme covering:

- Phishing.
- Password security.
- MFA.
- Social engineering.
- Safe use of personal devices.
- Data protection.
- Incident reporting.
- Secure use of cloud applications.

Hail could also conduct periodic simulated phishing exercises to measure employee awareness.

Responsible owner: Security Lead / HR

Deadline: 90 days

Priority: Medium

Review the above mitigation plan on the chart below:

ID	Risk	Mitigation	ISO 27001 Alignment	Owner	Deadline
F-01	MFA not enforced	Implement MFA across corporate accounts	A.5.8	IT/Security	30 days
F-02	No centralised SSO	Implement central identity/SSO	A.5.16, A.5.18	IT/Security	60 days
F-03	Sensitive data exposure	Classification, access controls, sharing restrictions & monitoring	A.8.11, A.8.12, A.8.24	IT/Data Owner	60 days
F-04	No incident response	Create and test IR plan	A.5.24, A.5.28	Security	30 days
F-05	Lack of policies	Develop security policy framework	Clause 5.2, A.5.1	Management/Security	60 days
F-06	No vulnerability scanning	Establish vulnerability management process	A.8.8	IT/Security	60 days
F-07	BYOD weaknesses	Implement BYOD requirements + MDM/EDR evaluation	A.7.13, A.8.1, A.8.20	IT/Security	90 days
F-08	No access reviews	Quarterly permission reviews	A.5.16, A.5.18	IT/Managers	60+ days
F-09	Limited training	Recurring security awareness programme	A.6.3	Security/HR	90 days

08- Hail Software LTD's 90 Day Cybersecurity Improvement Roadmap

Stage 1 — Immediate Risk Reduction

30 Days

Objective: Address the highest-impact weaknesses first.

Authentication

- Implement MFA for Slack and GitHub.
- Prioritise privileged accounts.
- Begin review of existing authentication methods.

Incident Response

- Create Incident Response Plan.
- Define incident reporting and escalation.
- Identify responsible personnel.
- Establish emergency communication channels.

Security Governance

- Begin drafting Information Security Policy.
- Define security responsibilities.
- Establish policy ownership and review dates.

Data Security

- Review sensitive data stored in Google Drive.
- Identify who currently has access.
- Remove unnecessary permissions.
- Restrict inappropriate external sharing.

Outcome

Reduce immediate risk exposure and establish foundational controls

Stage 2 — Build the Security Foundation

60 Days

Objective: Formalise security controls and introduce repeatable processes.

Identity Management

- Evaluate central IdP/SSO implementation.
- Establish centralised account-management procedures.
- Define joiner/mover/leaver processes.

Vulnerability Management

- Establish routine vulnerability scanning.
- Create vulnerability register.
- Define severity and remediation priorities.
- Assign remediation owners.

BYOD

- Develop BYOD policy.
- Define minimum device security requirements.
- Evaluate MDM/EDR options.

Data Security

- Complete data classification exercise.
- Review access permissions.
- Establish appropriate data-sharing restrictions.

Outcome

Establish repeatable security processes and strengthen control framework.

Stage 3 — Improve Security Maturity

90 Days

Objective: Establish an ongoing security culture rather than one-off fixes.

Security Awareness

Launch mandatory employee security training covering:

- Phishing
- Social engineering
- Passwords
- MFA
- Data protection
- BYOD
- Incident reporting

Access Management

Conduct the first formal **quarterly access review**.

Incident Response

Conduct a tabletop exercise.

For example:

Scenario: An employee's GitHub credentials have been compromised.

Ask:

- Who identifies the incident?
- Who is notified?
- How is the account contained?
- How are credentials reset?
- Who communicates with management?
- How is evidence preserved?
- How are lessons learned recorded?

Vulnerability Management

Conduct the first follow-up vulnerability scan and verify that identified weaknesses have been remediated.

Outcome

Build security culture, validate controls and drive continuous improvement

See the simulated continuous security improvement below:

HAIL SOFTWARE LTD – SECURITY ROADMAP

From Risk Assessment to Continuous Improvement

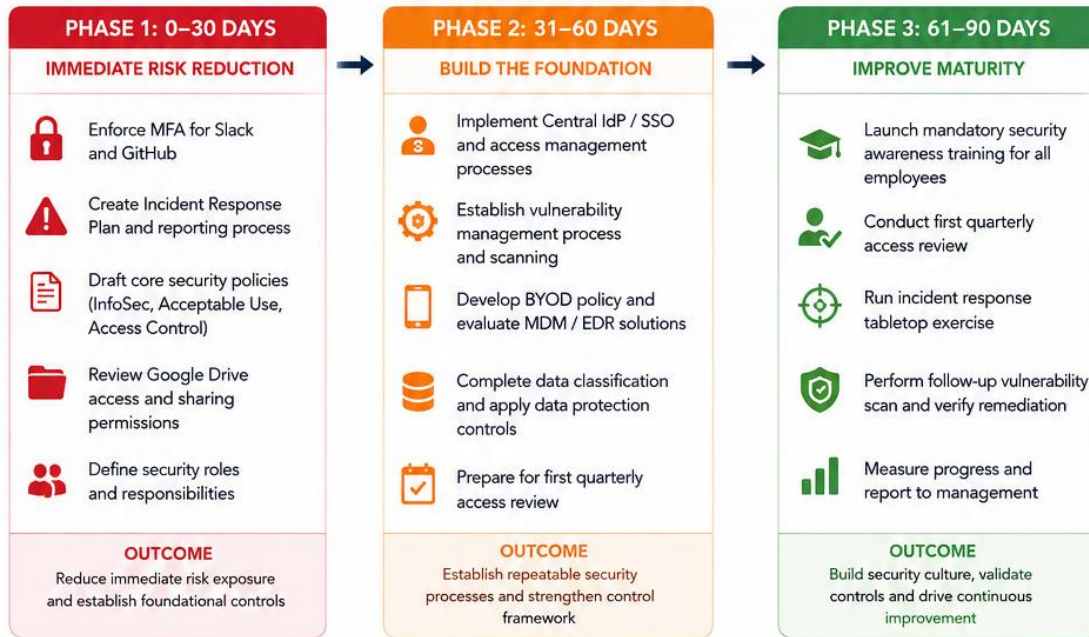


BASED ON HAIL SOFTWARE LTD RISK ASSESSMENT FINDINGS

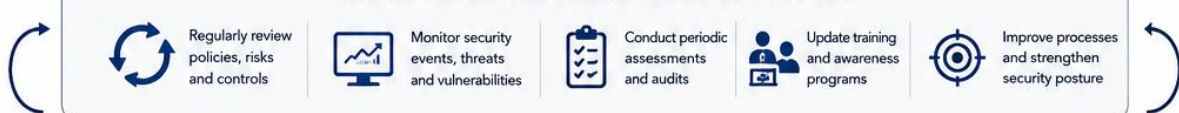
KEY RISKS IDENTIFIED (9 FINDINGS)



90-DAY SECURITY ROADMAP



CONTINUOUS IMPROVEMENT (ONGOING AFTER 90 DAYS)



END GOAL

A secure, resilient and ISO 27001-aligned environment that protects Hail Software LTD and supports business growth.

KEY BENEFITS

- Reduced risk of breaches and incidents
- Stronger access controls and data protection
- Improved compliance with ISO 27001 controls
- Increased employee awareness and accountability
- Enhanced customer trust and business resilience

PRIORITY KEY: ● High (Immediate / 0–60 Days) ● Medium (31–90 Days) ● Ongoing (90+ Days)

Figure 1 90-Day Security Roadmap

09 – Conclusion

Hail Software LTD has been given a structured approach to reduce the cybersecurity risks identified during the assessment. The recommended actions aim to strengthen authentication and access management, protect sensitive information, control technological vulnerabilities, build incident response capabilities, formalise security governance, protect employee endpoints and raise security awareness.

Measures that reduce the immediate risk of account compromise, unauthorised access, data exposure and operational disruption should be prioritised. These include implementing multi-factor authentication, creating an incident response plan, strengthening information security policies and reviewing who has access to critical data.

The roadmap's later stages focus on establishing sustainable and continuous security procedures, such as staff security awareness, BYOD governance, vulnerability management and access control reviews.